

Enterprise Security & GDPR Compliance Whitepaper

Document ID: CC-SEC-WP-2026-05 | Version: v1.4.7 | Classification: Public / Customer-Grade | Date: 2026-06-02

At Clean-Core.io, we recognize that custom SAP legacy code (ABAP) contains highly proprietary business logic, core process knowledge, and intellectual property. Migrating and refactoring this logic requires an absolute commitment to data isolation, modern cryptographic standards, and strict adherence to European data sovereignty laws. This whitepaper details the architectural, cryptographic, and operational guardrails established on Clean-Core.io to ensure full compliance and data safety.

1. Data Sovereignty & GDPR (DSGVO) Compliance

Clean-Core.io is engineered as a fully sovereign, European-hosted modernization platform. All storage and processing layers comply strictly with the General Data Protection Regulation (GDPR / DSGVO):

✓ STRICTLY EU-HOSTED PROCESSING (ART. 25 GDPR)

All database operations, project documents, and processing routes run exclusively in the **BELGIUM (EUROPE-WEST1)** cloud region on GCP. No data is transferred or cached outside the European Union.

- **Art. 17 GDPR (Right to Erasure):** We implement a strict cascading delete policy. When a user triggers "Delete Profile" from the Settings Danger Zone, the platform initiates an atomic transaction that permanently deletes their Firebase Authentication entry, all Firestore project documents, and all stored files from the storage bucket.
- **Data Minimization (Art. 5 GDPR):** The system collects only the minimal authentication records required (Name, Email) and strictly processes uploaded ABAP code to extract abstract syntactic structures. No actual master or transactional business records (e.g., customer addresses or bank details) are parsed or processed.

2. Browser-Side Cryptographic Vault (BYOK)

Clean-Core.io features a pioneering **Bring Your Own Key (BYOK)** capability to give enterprises full control over their generative AI resources.

BROWSER-SIDE PBKDF2 & AES-GCM ENCRYPTED VAULT

When a pilot user registers their own Google Gemini API key:

1. The key is encrypted directly inside the user's browser using the native Web Cryptography API (SubtleCrypto).
2. We derive a 256-bit AES key using PBKDF2 with 100,000 iterations and a dynamic, random salt.
3. The key is encrypted in authenticated **AES-GCM mode**, guaranteeing that the raw key never transit or sit on our database in plaintext.

3. Stateless AI Orchestration & Model Training Isolation

A common concern for enterprise IT is the use of source code by AI providers for model tuning or training.

- **Stateless API Proxying:** The Clean-Core.io server-side backend proxies Gemini AI requests using enterprise-level, stateless Google Cloud Vertex AI API configurations. E2E transformation calls are treated as transactional API runs.
- **Training Deactivation:** In accordance with Google Cloud Enterprise Agreement terms, all code snippets sent to the backend `/api/gemini` proxy are **excluded from LLM model training and reinforcement cycles**. Your intellectual property remains strictly yours.

4. Live S/4HANA Connection Sandbox Isolation

The S/4HANA Live Tenant Integration Feature (BYOT) in Stage 5 enables developers to run OData validation tests directly against non-productive S/4HANA environments. To safeguard the host ERP network:

- **Production Domain Blocklist:** The server-side sandbox proxy intercepts S/4HANA Tenant URLs and enforces a strict regex blocklist, rejecting any connections matching known production IP address ranges or SAP production host patterns.
- **Encrypted Firestore Storage:** ERP tenant integration credentials (username/password/OAuth secrets) are stored in your Firestore user document under strict Firestore Security Rules, ensuring they are only accessible to the authenticated owner and the sandboxed server runtime.

